

Cybersecurity Training Diary

Day 20: Compliance & Security Standards

1. Topics Covered

✓ Major Security Standards

Standard	Focus Area	Key Requirement
ISO 27001	Information Security	Risk management, continuous improvement
NIST CSF	Cybersecurity Framework	Identify, Protect, Detect, Respond, Recover
GDPR	Data Privacy (EU)	Right to be forgotten, breach reporting
PCI DSS	Payment Security	Secure cardholder data (encryption, access controls)

✓ Compliance Workflow

```
graph TD
  A[Gap Analysis] --> B[Policy Creation]
  B --> C[Implementation]
  C --> D[Internal Audit]
  D --> E[Certification]
```

✓ Common Compliance Tools

- **GRC Platforms:** RSA Archer, ServiceNow GRC
- **Automation:** Terraform for CIS Benchmark compliance
- **Documentation:** Confluence, SharePoint

2. Key Takeaways

- ✓ **Compliance ≠ Security:** Being compliant doesn't mean you're fully secure
- ✓ **Start with NIST CSF** if new to frameworks (free & adaptable)
- ✓ **Automate compliance checks** where possible (e.g., AWS Config Rules)

3. Practical Exercises

♦ Exercise 1: Map Controls to MITRE ATT&CK

PCI DSS Requirement	MITRE Tactic	MITRE Technique
8.2.4 (MFA)	Initial Access	T1110 (Brute Force)
10.2 (Logging)	Discovery	T1083 (File/Dir Discovery)

♦ Exercise 2: Run CIS Benchmark Scan

```
# Linux example
sudo lynis audit system --tests-from-group authentication
```

4. Questions for Reflection

- ? Why do some companies struggle with compliance?
- ? How could AI help with compliance monitoring?